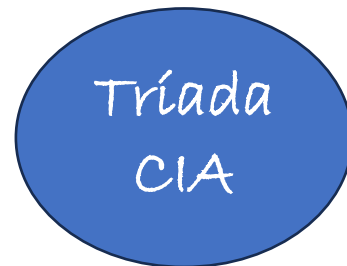


4 de mayo
de 2026

Clase 6

Seguridad Informática

→ preservar



Confidencialidad

Guardar info en secreto
(Acceso a autorizados)

Integridad

confiabilidad

- Integridad de datos
- Integridad de origen

Disponibilidad

Poder usar la info

Políticas Mecanismos

Qué acciones son
seguras
(permitidas)
y qué acciones son
inseguras
(prohibidas)

Procedimiento,
herramienta o
método para
garantizar
cumplimiento de
política

Prevenir

Detectar

Recuperar

Típos de Control de Acceso

una política de seguridad puede usar

DAC

Díscrecional

Basado en Identidad

Políticas se definen para el
usuario

MAC

Mandatorio

Basado en Reglas

Políticas se definen para el
sistema

Modelos de Seguridad

Un modelo de seguridad es una definición formal de una **Política de Seguridad**

A través de una sustentación formal, matemática se demuestra que el sistema es seguro.



Modelo de
Bell - LaPadula
Confidencialidad

Modelo de
Biba

Integridad



Modelo de Bell - LaPadula

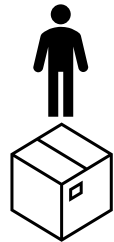
Objetivo: Prevenir el acceso no autorizado a la información.
las modificaciones no autorizadas son secundarias.

➤ Combina acceso **mandatorio** y acceso **discrecional**

Elementos:

✓ Sujetos

✓ Objetos



✓ Modos de acceso = {read, write, ...}

✓ Clasificación de seguridad = {TS, S, C, U...}

✓ Niveles de seguridad = Clasificación x Categoría (red)

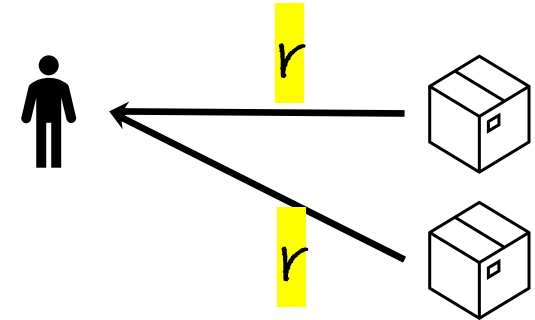
Ej: = {(Top Secret, {OTAN, MERCOSUR, ...})
(Confidencial, {MERCOSUR})...}

Principios:

Condición de Seguridad Simple - Read Down

El sujeto s puede leer el objeto o si y solo si

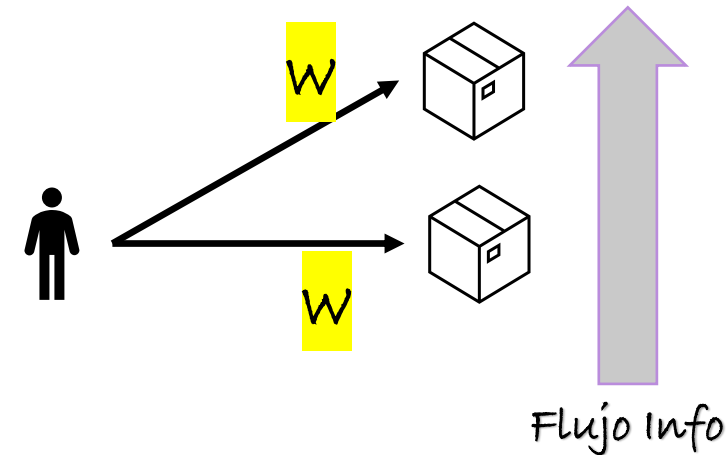
$L(s) \text{ dom } L(o)$ y s tiene permiso para leer o .



Propiedad * - Write Up

El sujeto s puede escribir el objeto o si y solo si

$L(o) \text{ dom } L(s)$ y s tiene permiso para escribir o .



Domínancia: (L, C) domina a (L', C') si y sólo si $L' \leq L$ y $C' \subseteq C$

Modelo de Biba

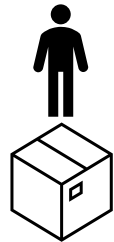
Objetivo: Preservar los datos y su integridad.

Identifica maneras autorizadas en las cuales la información puede ser alterada y cuáles son las entidades autorizadas para hacerlo.

Elementos:

✓ Sujetos

✓ Objetos



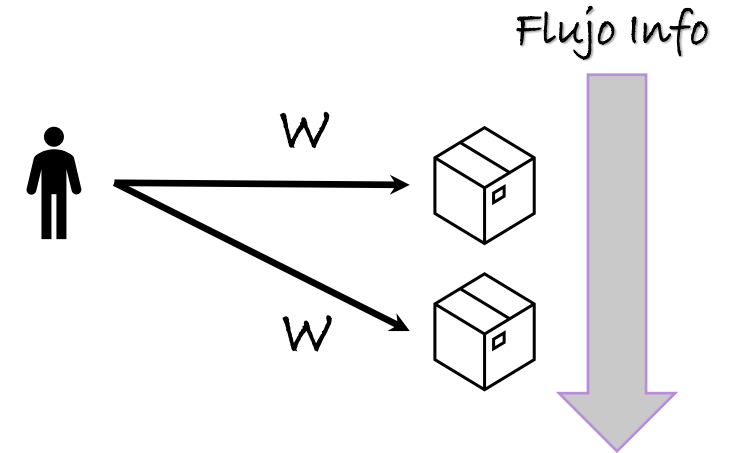
✓ Modos de acceso = {read, write, ...}

✓ Niveles de integridad = $il()$ → a mayor nivel mayor confianza

Principios

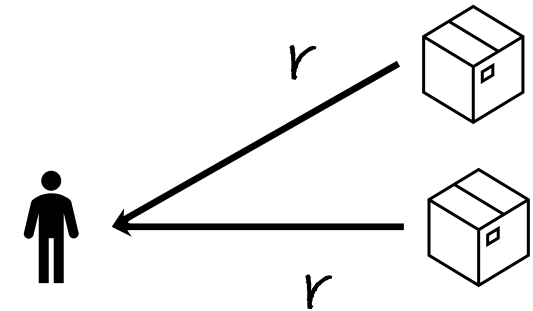
1. Escritura - Write Down

El sujeto s puede modificar el objeto o sí y solo sí $il(s) \geq il(o)$.



2. Lectura - Read Up (Bíba Estricto)

El sujeto s puede observar el objeto o sí y solo sí $il(o) \geq il(s)$



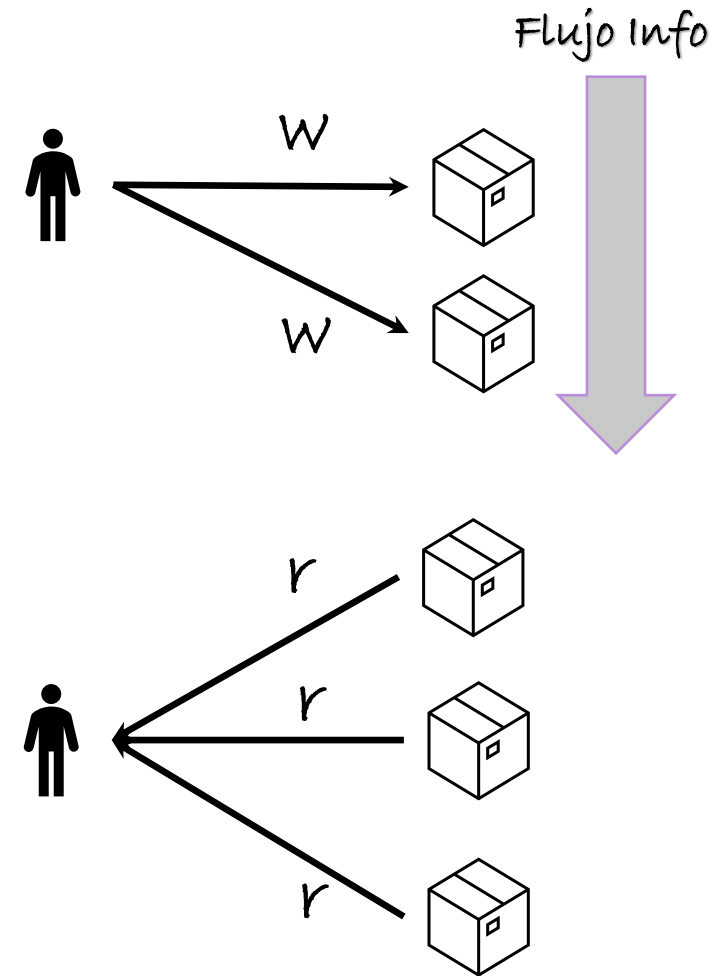
Principios

1. Escritura - Write Down

El sujeto s puede modificar el objeto o sí y solo sí $il(s) \geq il(o)$.

2. Lectura - Read (Biba Ring-Policy)

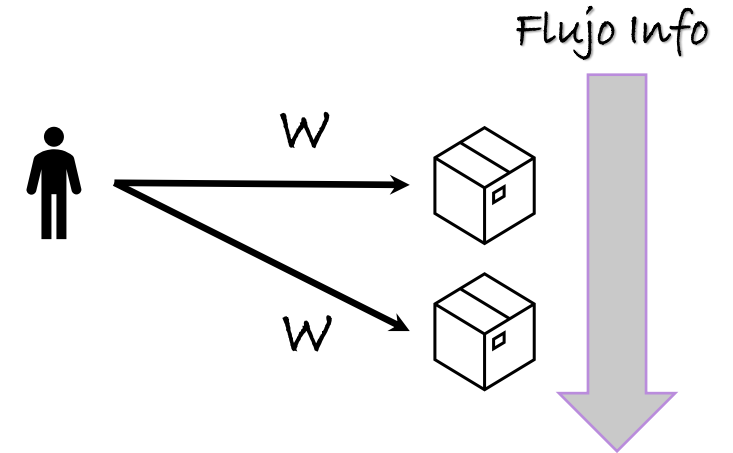
Cualquier s puede leer cualquier o .



Principios

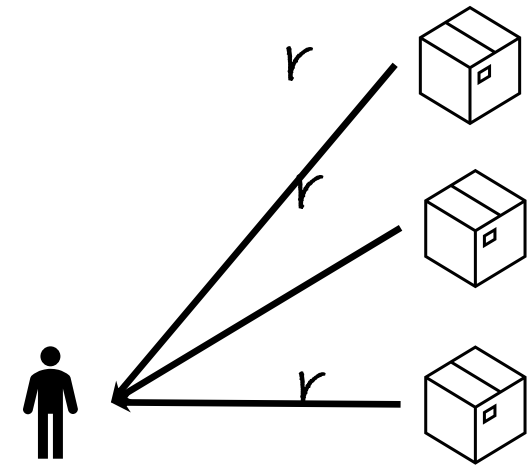
1. Escritura - Write Down

El sujeto s puede modificar el objeto o sí y solo sí $il(s) \geq il(o)$.



2. Lectura - Read (Biba Low-Watermark)

Sí s lee o , $il(s) = \min(il(s), il(o))$.





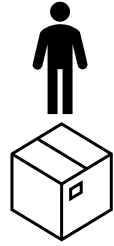
Modelo Clark Wilson

Objetivo: Integridad, especialmente en entornos comerciales.

Elementos:

✓ Sujetos

✓ Objetos



- Restringidos = CDI (Constrained Data Items)

- No restringidos = UDI (Unconstrained Data Items)

✓ Procedimientos: Administran accesos y permisos

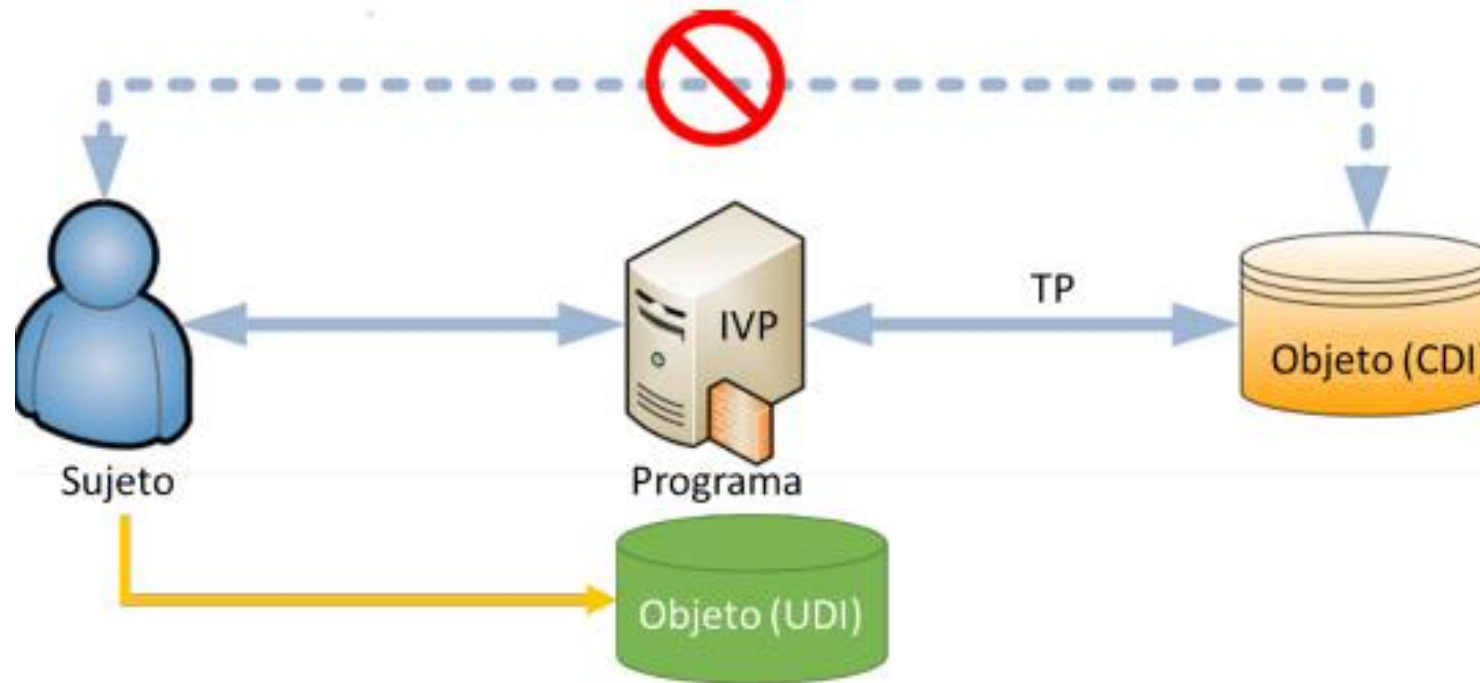
- De Transformación (TP = Transformation Procedure)

- Cambia los ítems de un estado válido (consistente) a otro estado válido.

- De Verificación de integridad (IVP = Integrity Verification Procedure)

- Verifica que los ítems están en un estado válido.

- Un usuario no puede modificar un CDI en forma directa. Debe hacerlo a través de un TP.
- Un usuario sí puede tener acceso a datos UDI sin el uso de un TP.



Reglas

1. De Certificación (Certification Rules = CR)

- De monitoreo de integridad (Integrity monitoring rules)
- Discrecionales, aplicadas por el Administrador.

C₁= (Certificación) Los IVP aseguran que los CDI están en un estado válido.

C₂= (Validez) Un TP toma un estado válido y lo lleva a otro estado válido. $TPI, \{CDIa, CDIb, CDIc, \dots\}$

C₃= (Separación de tareas) Las *relaciones certificadas* que asocian un conjunto de CDI con un TP lo cumplen.

C₄= (Journal certification) En un CDI tipo bitácora los TP guardan información para reconstruir operación

C₅= (Validación de UDI) Los TP validan UDI (O convierte el UDI en un CDI válido, o el UDI es rechazado)

2. De Aplicación (Enforcement Rules = ER)

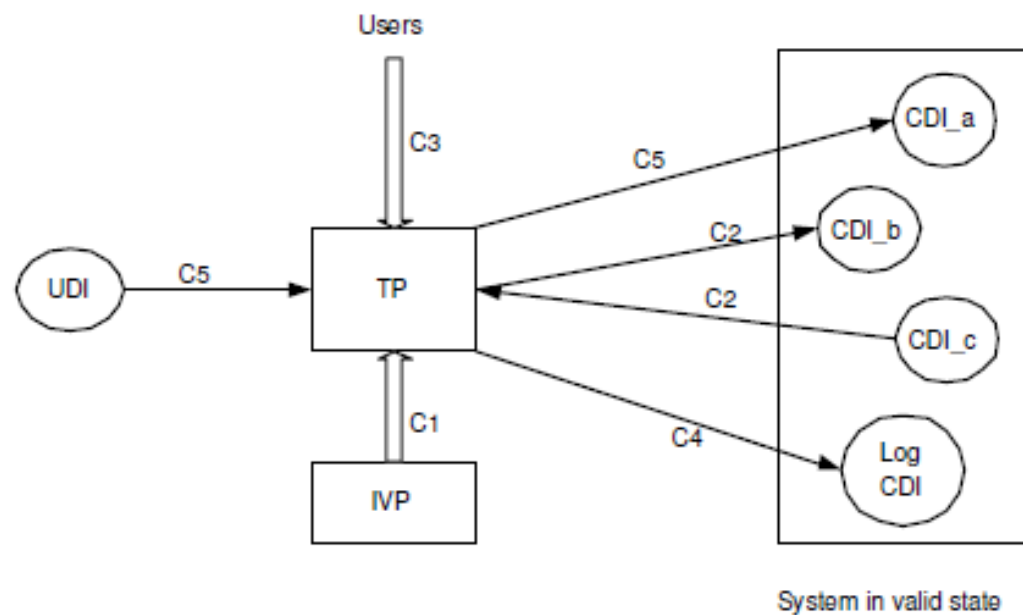
- De preservación de integridad (Integrity preserving rules)
- Mandatorias, aplicadas por el Sistema.

E₁= (Aplicación de validez) El sistema mantiene lista de relaciones certificadas. $TPf \text{ opera sobre } CDIo \Leftrightarrow (f,o) \in C$

E₂= (Aplicación de separación de tareas) El sistema mantiene lista de relaciones permitidas. $(UserID, TPI, \{CDIa, \dots\})..$

E₃= (Identificación de usuarios) El sistema debe autenticar a quien intenta ejecutar el TP.

E₄= (Cambios) Las autorizaciones sólo las puede cambiar el administrador.



Certification Rules

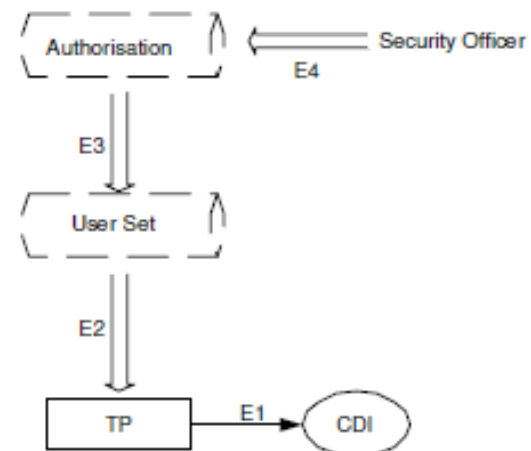
C1: IVP validates CDI state

C3: Suitable separation of duty

C5: TPs validate

C2: TPs preserve valid state

C4: TPs write to log file



Enforcement Rules

E1: CDIs changed only by authorised TP

E3: Users are authorised

E2: Users authorised for TP

E4: Authorisation lists changed only by security officer

(b) Enforcement Rules

¿Qué sistemas se basan en...

- Bell Lapadula?

Sistemas de información médica.

- Biba?

Sistemas de información fiscal, judicial, prensa

- Clark Wilson?

Sistemas operativos como Unix.

Lectura Recomendada sobre Modelos:

- Bell76.pdf
(Documento original Modelo Bell-LaPadula)
- Biba75.pdf
(Documento original Modelo Biba)
- A_Comparison_of_commercial_and_military.pdf
(Documento original Modelo Clark Wilson)

Clase 6 - Segunda Parte

Control de acceso:

Regula quién  puede acceder a qué  y bajo qué condiciones.

Típos de Control de Acceso

DAC

Díscrecional

Basado en Identidad

a díscreción del sujeto
responsable del objeto o un
administrador.

MAC

Mandatorio

Basado en Reglas.

Obligatorio para todos los accesos
de los sujetos a los objetos

Mecanismos de Control de Acceso

ACLs

Matríz:

Capability
lists

	Obj1	Obj2	...	ObjN
Usuario1	r	rw		rwX
Usuario2	rx	r		rx
...				

- Escalabilidad
- Eficiencia
- Mantenimiento
- Almacenamiento



Lísten de Control de Acceso

Las columnas de la matriz

$$ACL(o) = \{(s_i, p_i) / s_i \in S \wedge p_i \subseteq R\}$$

S = sujetos
 O = objetos
 R = permisos

Denegar por defecto: Si s no está en $ACL(o) \rightarrow$ no tiene permiso sobre o .

Grupos: $G = \{s_1, s_2, \dots, s_i / s_i \in S\}$.

$$ACL(o) = \{(s_1, r), (G, rw), \dots\}.$$

Wildcards: $ACL(o) = \{(s_1, r), (s_2, *) \dots\}.$

Conflictos:

- Si más de una entrada en ACL dan permisos $\neq$ a s:
 1. Permitir acceso si alguna entrada da acceso.
 2. Grant All: Denegar acceso si alguna entrada deniega acceso.
(Exige que todas den acceso)
 3. First Rule/First Match: Aplicar 1ª regla encontrada.

$ACL(o) = \{ (G, rw), (s_1, w), (\{s_1, s_2\}, wx), \dots \}$.

Si s_1 es de G :

1. Puede r, w, x
2. Grant All: puede w .
3. First Rule: puede r y w .

Derechos por defecto

- Otras reglas aplicables:

1. Override/Best match:

Sí el sujeto tiene una entrada específica, usarla.

Síno, usar default.

1. Augment: Partir del default y agregar entradas explícitas.

$ACL(o) = \{ (s_1, x), (*, r), \dots \}$.

El sujeto s_1

1. Override: puede x .

2. Augment: puede r (por que todos pueden) y x .

Usuarios privilegiados, transferencias y revocaciones

- Usuarios privilegiados:
 1. Root o administrador.
 2. Owner → puede modificar el ACL del objeto sobre el que tiene derecho "own".
- Transferencia: cambia el sujeto de una entrada. El sujeto1 deja de tener derechos, pasan al sujeto2.
- Delegación: El sujeto1 le delega derechos al sujeto2, sin perderlos.
- Revocación: El owner quita la entrada o quita derechos. Si hubo delegación → revocación en cascada.

RBAC (Role-based Access Control):

- Los roles se asignan a los sujetos.
- Los permisos se asignan a los roles.
- Considera jerarquías de roles.

ABAC (Attribute-based Access Control):

- Basadas en atributos del sujeto (ej rol, edad...), del objeto (tipo, clasificación de seguridad...), de la acción, del contexto (tiempo, ubicación, ...)